

ZANOVO SECURITY HARDENING REPORT

Prepared locally for /Users/tk/Claude/Projects/Zanovo on 2026-05-08

Status: implemented, deployed, and verified

EXECUTIVE SUMMARY

The Zanovo contact form was hardened from a direct browser-to-database submission flow into a server-validated Supabase Edge Function workflow. The database was locked down with RLS, field constraints, and private service-role access. The Edge Function now validates input, rate-limits submissions, stores leads securely, and sends lead notifications through Zoho SMTP.

The localhost error seen at the end of testing was caused by a CORS origin mismatch between localhost and 127.0.0.1. The allowed origins were updated and verified.

WORK COMPLETED

1. Frontend Contact Form Hardening

Removed the active Supabase browser client dependency, removed direct client inserts into leads, added validation, max lengths, a honeypot field, and function-only submission.

Change notes:

/Users/tk/Claude/Projects/Zanovo/security-report/change-notes/01-frontend-contact-form-hardening.txt

Changed source:

/Users/tk/Claude/Projects/Zanovo/src/App.jsx

2. Supabase RLS, Constraints, and Rate Limiting

Added SQL migration to create/harden leads, enforce RLS, revoke anonymous access, create a private rate-limit table, and add a rate-limit RPC.

Change notes:

/Users/tk/Claude/Projects/Zanovo/security-report/change-notes/02-supabase-rls-and-rate-limit-migration.txt

Changed source:

/Users/tk/Claude/Projects/Zanovo/supabase/migrations/202605080001_harden_leads.sql

3. Edge Function Validation, Storage, and Zoho SMTP

Added and deployed send-lead-email. It validates payloads server-side, rate-limits, inserts through service-role credentials, and sends email through Zoho SMTP with escaped HTML content.

Change notes:

/Users/tk/Claude/Projects/Zanovo/security-report/change-notes/03-edge-function-validation-storage-email.txt

Changed source:

/Users/tk/Claude/Projects/Zanovo/supabase/functions/send-lead-email/index.ts

4. Rate-Limit RPC Fix

Added a second migration to recreate the rate-limit RPC with parameter names that do not collide with table columns, then updated the Edge Function

RPC call.

Change notes:

/Users/tk/Claude/Projects/Zanovo/security-report/change-notes/04-rate-limit-rpc-fix.txt

Changed sources:

/Users/tk/Claude/Projects/Zanovo/supabase/migrations/202605080002_fix_lead_rate_limit_rpc.sql

/Users/tk/Claude/Projects/Zanovo/supabase/functions/send-lead-email/index.ts

5. Environment and Secret Configuration

Corrected the local Supabase URL from .supabase.com to .supabase.co. Set function secrets for rate limiting, CORS, and Zoho SMTP. Secret values are intentionally not recorded.

Change notes:

/Users/tk/Claude/Projects/Zanovo/security-report/change-notes/05-env-and-supabase-secrets.txt

Changed source:

/Users/tk/Claude/Projects/Zanovo/.env

6. Verification

Verified build, lint, local dev server startup, SQL migration push, function deployment, live Edge Function tests, live Zoho SMTP tests, and localhost CORS tests.

Change notes:

/Users/tk/Claude/Projects/Zanovo/security-report/change-notes/06-verification-results.txt

FINAL VERIFICATION RESULTS

- npm run build: passed.
- npm run lint: passed.
- supabase db push: applied the RPC fix migration.
- supabase functions deploy send-lead-email: deployed successfully.
- Live Edge Function test: returned {"ok":true}.
- Live Zoho SMTP test: returned {"ok":true}.
- Localhost CORS test from http://127.0.0.1:5175: passed.

REMAINING OPERATIONAL NOTES

- Keep Zoho SMTP credentials as Supabase secrets only. Do not commit them to source control.
- For production, keep ALLOWED_ORIGINS limited to the real site domains plus temporary localhost origins only while developing.
- If the contact form is copied into another project, copy the Edge Function, migrations, and secrets checklist too.
- The backup file src/zanovo-website_1.jsx still contains the old direct insert pattern, but it is not imported by the active app. Avoid using it as production source unless it is hardened too.

REUSABLE FUTURE PROMPTS

Security Review Prompt:

Review this codebase for security risks. Prioritize concrete exploitable issues over style feedback. Check authentication, authorization, secrets handling, input validation, database access, CORS, XSS, CSRF, SSRF, rate limiting

g, logging, and deployment configuration. Give findings by severity with file and line references, then propose fixes.

Implement Fixes Prompt:

Implement the high-priority security fixes directly. Keep a checklist and tick it off as you work. Preserve existing design and behavior where possible. After changes, run build/lint/tests and summarize exactly what changed and what still needs manual deployment or secret configuration.

Supabase Form Hardening Prompt:

Harden this public Supabase contact form. Remove direct browser table inserts, route submissions through a Supabase Edge Function, enable RLS, add DB constraints, server-side validation, rate limiting, safe CORS, and secure email notification. Keep Supabase service-role credentials only in Edge Function secrets.

Deployment Verification Prompt:

Verify the deployed app end to end. Test the local dev server, production build, Supabase migrations, Edge Function deployment, function secrets, CORS preflight, live POST submission, database insert, and email delivery. If something fails, diagnose and patch it directly.

Project Report Prompt:

Create a PDF report of all work done. Include every changed file, every security fix, validation results, deployment steps, remaining risks, and reusable prompts. Create per-step text files for code/config changes and link to them from the report.